

中华人民共和国通信行业标准

YD/T××××—××××

移动智能终端人工智能应用的个人信息保护技术要求及评估方法

Technical requirements and evaluation methods for personal information protection
of Mobile smart terminals' AI application

(报批稿)

××××-××-××发布

××××-××-××实施

中华人民共和国工业和信息化部发布

目 次

前 言.....	II
1 范围.....	1
2 规范性引用文件.....	1
3 术语、定义.....	1
3.1 术语和定义.....	1
4 缩略语.....	2
5 移动智能终端人工智能应用个人信息概述.....	2
5.1 个人信息分类.....	2
5.2 基本原则.....	3
5.3 个人信息处理环节.....	4
6 移动智能终端人工智能应用的个人信息保护技术要求.....	4
6.1 个人信息的采集.....	4
6.2 个人信息的训练.....	5
6.3 个人信息的分析.....	5
6.4 个人信息的存储.....	6
6.5 个人信息的转移.....	7
6.6 个人信息的共享与转让.....	8
6.7 个人信息的披露.....	8
6.8 个人信息的删除.....	9
7 移动智能终端人工智能应用的个人信息保护评估方法.....	9
7.1 评估判定准则.....	9
7.2 个人信息的采集.....	9
7.3 个人信息的训练.....	12
7.4 个人信息的分析.....	13
7.5 个人信息的存储.....	14
7.6 个人信息的转移.....	19
7.7 个人信息的共享与转让.....	21
7.8 个人信息的披露.....	23
7.9 个人信息的删除.....	24
参 考 文 献.....	25

前 言

本文件按照GB/T 1.1-2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

本文件由中国通信标准化协会提出并归口。

请注意本文件的某些内容可能涉及专利，本文件的发布机构不承担识别专利的责任。

本文件起草单位：中国信息通信研究院，华为技术有限公司，北京小米移动软件有限公司，OPPO广东移动通信有限公司，维沃移动通信有限公司，北京百度网讯科技有限公司，北京奇虎科技有限公司、北京三星通信技术研究有限公司、郑州信大捷安信息技术股份有限公司。

本文件主要起草人：刘陶、傅山、吴怡、宁华、杨萌科、武林娜、杜云、王艳红、衣强、常新苗、王江胜、吴越、贾科、姚一楠、黄天宁、吴月升、刘献伦、陈鑫爱、周飞、李京典、李可心。

移动智能终端人工智能应用的个人信息保护技术要求及评估方法

1 范围

本文件规定了移动智能终端人工智能应用的个人信息保护技术要求和评估方法,提出了移动智能终端人工智能应用的个人信息保护基本原则,定义了产业链各方在个人信息保护中的角色和职责,规范了人工智能业务所涉个人信息的类型,结合各类信息特点,对相应类型的个人信息保护提出技术要求和对应的评估方法。

本文件适用于移动智能终端人工智能应用的个人信息保护的设计、开发以及安全评测。个别条款不适用于特殊行业、专业应用,其他类型终端产品的人工智能应用也可参考使用。

2 规范性引用文件

下列文件对于本文件的应用是必不可少的。凡是注日期的引用文件,仅所注日期的版本适用于本文件。凡是不注日期的引用文件,其最新版本(包括所有的修改单)适用于本文件。

GB/T 25069-2010 信息安全技术 术语

GB/T 35273-2020 信息安全技术 个人信息安全规范

YD/T 2407 移动智能终端安全能力技术要求

3 术语、定义

3.1 术语和定义

GB/T 25069-2010、GB/T 35273-2020、YD/T 2407 中界定的以及下列术语和定义适用于本文件。

3.1.1

移动智能终端 smart mobile terminal

能够接入移动通信网,具有能够提供应用软件开发接口的操作系统,具有安装、加载和运行应用软件能力的终端。

[YD/T 2407 移动智能终端安全能力技术要求,定义3.1.1]

3.1.2

人工智能 Artificial Intelligence

能以人类智能(如推理和学习)相似的方式做出反应的计算机程序,包括语音识别、图像识别、自然语言处理和专家系统等。

3.1.3

人工智能应用 Artificial Intelligence application

集成一类或多类人工智能应用技术，面向特定应用场景需求，完成具体任务指令的业务模块。例如：AI语音交互、生物特征识别等。

3.1.4

用户画像 user profiling

通过采集、汇聚、分析个人信息，对某特定自然人个人特征，如其职业、经济、健康、教育、个人喜好、信用、行为等方面做出分析或预测，形成其个人特征模型的过程。

注：直接使用特定自然人的个人信息，形成该自然人的特征模型，称为直接用户画像。使用来源于特定自然人以外的个人信息，如其所在群体的数据，形成该自然人的特征模型，称为间接用户画像。

3.1.5

训练数据 training data

指进行AI模型训练时使用的数据。

4 缩略语

下列符号和缩略语适用于本文件。

AI	人工智能	Artificial Intelligence
API	应用程序编程接口	Application Programming Interface

5 移动智能终端人工智能应用个人信息概述

5.1 个人信息分类

5.1.1 概述

移动智能终端人工智能应用所涉个人信息主要包含生物特征、语音图像、位置轨迹、行为习惯、账户凭证、业务信息、身份信息、设备信息共八大类别，涉及包括移动智能终端人工智能模块处理、用户存储及程序生成等各类个人信息。

5.1.2 生物特征类

是指移动智能终端自然人用户所固有的生理特征及行为特征信息，生理特征如指纹、虹膜、面部识别特征、DNA等，行为特征如步态、击键习惯等。

5.1.3 语音图像类

是指在移动智能终端生成或通过存储卡、网络传输、无线外围接口传输或计算机同步等方式进入终端人工智能模块，或由人工智能应用产生的各类多媒体个人信息数据，包括但不限于视频数据、音频数据、图片数据等。

5.1.4 位置轨迹类

是指与对一个或多个移动智能终端对象运动过程或静止位置的采样所获得的数据信息，包括但不限于采样点位置、采样时间、速度等，以及这些采样点数据信息根据采样先后顺序构成的轨迹数据等。

5.1.5 行为习惯类

是指对一个或多个移动智能终端用户的操作行为进行监测采样所获得的数据信息，包括但不限于用户网络浏览行为、用户购物记录等。

5.1.6 账户凭证类

是指移动智能终端人工智能应用所处理的用户账户信息，包括用户账户信息、口令密码、登录凭据等。

5.1.7 业务信息类

是指移动智能终端人工智能应用产生的业务相关用户个人信息，包括业务的控制信息、仓储物流信息等。

5.1.8 身份信息类

是指与移动智能终端用户身份证件相关的信息，包括但不限于身份证、军官证、护照、驾驶证、工作证等信息。

5.1.9 设备信息类

是指可唯一识别特定终端的硬件标识信息，以及反映用户使用偏好的软件信息，包括但不限于设备标识数据、卡标识数据、应用软件列表数据等。

5.2 基本原则

5.2.1 目的明确原则

移动智能终端人工智能应用处理个人信息应具有特定、明确、合理的目的，不扩大使用范围，不在个人信息主体不知情的情况下改变处理个人信息的目的。

5.2.2 最少必要原则

移动智能终端人工智能应用采集、使用和转移个人信息时不得扩大范围，只处理与其目的有关的最少信息，达到目的后不再继续处理个人信息。

5.2.3 告知同意原则

移动智能终端人工智能应用对使用者要尽到告知、说明和警示的义务。应以明确、易懂、适宜的方式如实告知，处理个人信息前要征得个人信息主体的同意，不得超告知范围处理个人信息。

5.2.4 安全保障原则

移动智能终端人工智能应用应保证加工或转移过程中个人信息的机密、完整、可用。应采取适当的、与个人信息遭受损害的可能性和严重性相适应的管理措施和技术手段，保护个人信息安全，防止未经使用者授权的检索、披露及丢失、泄露、损毁和篡改个人信息。

移动智能终端人工智能应用应允许个人信息主体删除所涉及的个人信息或匿名化处理,并确保个人信息不可恢复。

5.2.5 主动触发原则

移动智能终端人工智能应用处理个人信息应是在个人信息主体主动触发下进行,如需要主动采集、加工、转移个人信息必须具有特定、明确、合理的目的,且要满足可知可控原则。

移动智能终端人工智能应用对于可能删除个人信息的情况予以事先告知或说明。

5.3 个人信息处理环节

移动智能终端建立人工智能应用的个人信息数据处理涉及采集、训练、分析、存储、转移、共享、转让、披露、删除等阶段。对移动智能终端人工智能应用的个人信息保护技术要求贯穿于各个阶段中。

- a) 数据采集: 对移动智能终端人工智能应用所需的个人信息进行获取的过程;
- b) 数据训练: 对个人信息数据进行预处理并用于人工智能计算模块训练的过程;
- c) 数据分析: 使用人工智能计算模块对个人信息数据进行组合和分析的过程;
- d) 数据存储: 为人工智能应用所需将个人信息数据留存在移动智能终端上的过程;
- e) 数据转移: 移动智能终端建立人工智能应用向移动智能终端外部传输个人信息的过程;
- f) 数据共享: 个人信息控制者向其他控制者提供个人信息数据,且双方分别对个人信息拥有独立控制权的过程;
- g) 数据转让: 将个人信息控制权由一个控制者向另一个控制者转移的过程;
- h) 数据披露: 将个人信息向社会或不特定人群发布信息的行为;
- i) 数据删除: 使用删除或匿名化手段处理人工智能业务功能所涉个人信息数据,使其无法识别、不可被检索、访问的过程。

6 移动智能终端人工智能应用的个人信息保护技术要求

6.1 个人信息的采集

6.1.1 系统资源监控

人工智能应用应支持移动智能终端对用户个人信息相关系统资源,如地理位置、生物特征等的应用调用行为进行监控、保护和提醒,确保涉及应用采集个人信息的行为总是在受控的状态下,不会造成出现用户不可控的行为的执行。

6.1.2 采集告知

移动智能终端人工智能应用,在通过调用操作系统或其他安装的第三方软件系统提供的API接口或其它方式采集个人信息前,应告知用户,让用户知晓当前操作会采集个人信息的种类,以及采集的个人信息的用途。

6.1.3 最少采集

在采集个人信息过程中,移动智能终端人工智能应用只应采集能够达到已告知目的的最少信息。

6.1.4 配置功能

持续采集个人信息时,应允许移动智能终端人工智能应用使用者配置或关闭个人信息采集功能。关闭个人信息采集功能不应暂停个人信息主体自主选择使用的与所停止采集个人信息无关的其他业务功能,或降低与所停止采集个人信息无关的其他业务功能的服务质量。

6.1.5 无隐蔽采集

移动智能终端人工智能应用不应该采取隐蔽手段或未告知的间接方式采集个人信息。

6.1.6 敏感信息采集

采集个人敏感信息前,应征得个人信息主体的明示同意,并确保个人信息主体的明示同意是其在完全知情的基础上自主给出的、具体的、清晰明确的意愿表示;采集个人生物特征信息前,应单独征得个人信息主体的明示同意。

6.1.7 有效期告知

采集阶段的“告知”提醒,应明确采集使用存储的一个时间有效期,包括一段时间或长期等。

6.2 个人信息的训练

6.2.1 使用前处理

移动智能终端人工智能应用使用个人信息数据作为通用模型训练数据的,使用前应进行去标识化处理;如移动智能终端人工智能应用需使用非匿名化个人信息的,使用前应获得个人信息主体的授权同意。

6.2.2 训练数据安全防护

移动智能终端人工智能应用进行个性化AI模型训练时,应采用安全机制,防止攻击者窃取训练数据,造成个人信息泄露。

6.2.3 AI 模型安全

移动智能终端人工智能应用应采用安全机制保护AI模型的安全。例如,加密、完整性校验、反调试等。

6.3 个人信息的分析

6.3.1 处理前告知

移动智能终端人工智能应用在对个人信息进行分析处理前,应告知分析目的、方式或范围,不应超告知目的对个人信息数据进行分析处理。

6.3.2 处理过程安全

保证个人信息在分析处理过程中的安全性,在整个过程中个人信息不应被第三方无关人员或组织获知,过程数据和结果数据都应进行必要的安全保护。

6.3.3 处理系统安全

移动智能终端人工智能应用对个人信息进行分析处理时，应保证系统稳定安全运行，不造成个人信息的损毁、泄露和丢失等，分析过程完毕时应进行数据完整性检查。

6.3.4 处理过程可控

移动智能终端人工智能应用中个人信息处理过程应可控，终端设备使用者可配置或关闭分析功能。基于分析结果向个人信息主体提供个性化展示功能的，应显著区分个性化展示内容和非个性化展示内容，并同时向个人信息主体提供关闭该功能的选项。

6.3.5 无隐蔽处理

移动智能终端人工智能应用不应该在分析过程中采取隐蔽手段获取和挖掘用户的个人信息。

6.3.6 敏感信息明示授权

当对数据进行组合分析并可能产生的个人敏感信息的，移动智能终端人工智能应用应明示个人信息主体组合分析的目的、数据来源、使用范围等，并获得个人信息主体授权后方可进行分析处理。

6.3.7 申诉方法提供

当仅依据移动智能终端人工智能应用的自动决策而做出显著影响个人信息主体权益的定时（例如基于用户画像决定个人信用及贷款额度，或将用户画像用于面试筛选），应依据该自动决策对个人信息主体权益的影响程度，满足如下条款：

- a) 当该自动决策对个人信息主体产生法律效力时，应当确保人工进行事先审核和确认，该决定方可生效；
- b) 当该自动决策对个人信息主体产生的效力不属于 6.3.7 a) 所规定的情形时，应确保人工后续干预的能力，例如人工复核等。

此外，个人信息控制者应明确告知个人信息主体该决定是由人工智能应用生成的，个人信息主体有权对该决定提出异议。此时，个人信息控制者应确保该决定应在约定时间内进入人工复核流程，并在复核结果得出后提供申诉方法，并保证该申诉在约定时间内得到处理。

6.4 个人信息的存储

6.4.1 不超目的存储

个人数据存储的形式能够识别数据主体的程度不得超过数据处理目的的需要。

6.4.2 最小授权

应遵循最小授权原则，采用角色分离的方式设置移动智能终端上人工智能应用所涉个人信息数据的访问控制措施。

6.4.3 访问控制

移动智能终端人工智能应用在将位置轨迹类、行为习惯、身份信息、设备信息和业务信息类数据存储于终端内部时，应合理利用操作系统提供的文件保护和访问控制机制，以防止未授权的访问。

6.4.4 个人敏感信息安全防护

移动智能终端人工智能应用在存储用户个人敏感信息时应采用密码技术保证用户个人敏感信息在存储过程中的保密性、完整性，对于生物特征类、账户凭证类信息数据时，应避免存储其原始数据，数据宜采用密码技术经加盐后进行散列或杂凑运算后再保存，以增强变换结果抵御查表攻击的能力。

6.4.5 隔离保护

移动智能终端人工智能应用应将生物特征类、账户凭证类数据存储在被保护的受保护的受保护的系统区域内，并且为其设置适当的权限，以防止未授权的访问。宜使用专用硬件隔离区（例如集成在终端应用处理器内部的安全区域）来存储敏感个人信息。

6.4.6 最短时间保存

移动智能终端人工智能应用个人信息保存期限应为实现目的所必需的最短时间。超出上述个人信息保存期限后，应对个人信息进行删除或匿名化处理。

注：个人信息控制者履行法律法规规定的义务相关的情形除外。

6.4.7 去标识化存储

个人信息存储前，个人信息控制者宜立即进行去标识化处理，并采取技术和管理方面的措施，将去标识化后的数据与可用于恢复识别个人的信息采用逻辑隔离方式分开存储，并确保去标识化后的数据在不借助外部数据的前提下，在应用内后续处理中不能重新识别个人。

6.5 个人信息的转移

6.5.1 转移前告知

移动智能终端人工智能应用在进行个人信息数据传输转移前，应告知移动智能终端设备使用者当前个人信息转移的目的、转移信息的获得者、转移数据的使用范围。

6.5.2 不超范围转移

不对采集阶段告知范围以外的个人信息数据进行转移处理。

6.5.3 最少转移

基于最少够用的原则，优先本地处理，对于在本地加工处理能满足功能需求的个人信息数据，则不应进行数据的传输转移。

6.5.4 敏感信息授权

生物特征类个人信息不应被转移，确因业务需要的生物特征类个人信息转移需要经过用户明示同意，国家法律法规有其它要求确需转移的例外，账户凭证类等涉及个人敏感信息的个人信息，经移动智能终端人工智能应用个人信息主体同意授权后才可转移。

6.5.5 数据转移安全

个人信息的数据转移前，通信双方应通过有效技术手段进行身份鉴别和认证，数据转移过程应保证所转移数据的机密性、完整性，转移的个人敏感信息都应采取有效安全措施，如安全通道、数据加密等技术。

6.5.6 转移过程可控

个人信息数据的转移过程应可控，移动智能终端人工智能应用使用者可对转移功能进行配置或关闭操作。

6.6 个人信息的共享与转让

6.6.1 风险管理和应急响应

移动智能终端人工智能应用的个人信息控制者需与第三方共享、转让时，应充分重视风险，制定风险管理和应急响应预案。

6.6.2 告知与授权同意

个人信息控制者应向个人信息主体告知共享、转让个人信息的目的、数据接收方的类型以及可能产生的后果，并事先征得个人信息主体的授权同意。共享、转让个人敏感信息前，还应告知涉及的个人敏感信息类型、数据接收方的身份和数据安全能力，并事先征得个人信息主体的明示同意，共享转让方、接收方应共同承担用户个人信息保护的相应责任。个人生物识别信息原则上不应共享、转让，确因业务需要转让或共享的，应单独向个人信息主体告知并征得明示同意。

6.6.3 撤销同意

应向个人信息主体提供撤回共享、转让授权同意的办法。

6.6.4 不超范围共享转让

个人信息控制者不应将告知范围、目的以外的个人信息数据，共享、转让至第三方。

6.7 个人信息的披露

6.7.1 征得同意

原则上不应公开披露，经法律事由确需公开披露的，移动智能终端人工智能应用涉及公开或披露用户个人信息行为的，个人信息控制者应向个人信息主体告知公开披露个人信息的目的、类型、内容，并事先征得个人信息主体明示同意。

6.7.2 告知内容

移动智能终端人工智能应用公开披露个人敏感信息前，应向个人信息主体告知涉及的个人敏感信息的内容。

6.7.3 敏感信息披露

个人信息未经用户同意，不得公开披露。生物特征类、位置轨迹类、账户凭证类等个人敏感信息原则上不得公开披露，如确需公开披露的需提前获得用户明示同意。

6.7.4 信息披露的例外

符合GB/T 35273-2020 9.5节所列情形的，不必事先征得个人信息主体的授权同意。

6.8 个人信息的删除

移动智能终端人工智能应用对所使用的个人信息的缓存数据，应该提供自动删除或者手动删除功能，并保证被删除的个人信息不可被恢复。

7 移动智能终端人工智能应用的个人信息保护评估方法

7.1 评估判定准则

评估判定准则如下：

未见异常：移动智能终端人工智能应用在使用个人信息的过程中不存在窃取行为，或通过评测方法没有发现窃取行为没有发现存在安全风险或恶意行为；

风险：移动智能终端人工智能应用可能存在窃取（获取）行为，且通过评测方法发现在加工、转移隐私信息时未采取保护措施或不能判定其使用范围是否安全可靠。

恶意：移动智能终端人工智能应用在使用个人信息的过程中存在窃取行为，且通过评测方法发现存在用户不可知可控或超出目的范围的窃取行为。

7.2 个人信息的采集

测评编号：7.2.1
测评项目：资源调用受控
项目要求：6.1.1
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1，查看移动智能终端人工智能应用对用户个人信息相关系统资源的调用行为，如对地理位置、生物特征相关资源的读、写等行为，是否进行监控、保护和提醒； 步骤2，查看移动智能终端人工智能应用是否存在用户不可控情况下采集个人信息的行为；
预期结果： 在步骤2后，移动智能终端人工智能应用对系统资源的调用进行监控、保护和提醒，无在不受控的情况下采集个人信息的行为，则判定等级为“未见异常”，判定结束； 在步骤2后，移动智能终端人工智能应用对系统资源的调用未进行监控、保护和提醒，且存在不受控的情况下采集个人信息的行为，则判定等级为“恶意”，判定结束。

测评编号：7.2.2
测评项目：采集告知
项目要求：6.1.2
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：检查移动智能终端人工智能应用存在通过调用操作系统或其他安装的第三方软件系统提供的API接口或其它方式采集个人信息；

步骤2: 检查是否明确告知用户, 当前采集的个人信息种类, 以及采集的个人信息用途; 预期结果: 步骤1后, 如移动智能终端人工智能应用不存在通过调用操作系统或其他安装的第三方软件系统提供的API接口或其它方式采集个人信息, 则判定等级为“未见异常”, 判定结束; 步骤2后, 如移动智能终端人工智能应用通过调用操作系统或其他安装的第三方软件系统提供的API接口采集或其它方式个人信息前, 明确告知用户当前采集的个人信息种类以及采集的个人信息用途, 则判定等级为“未见异常”, 判定结束; 步骤2后, 如移动智能终端人工智能应用通过调用操作系统或其他安装的第三方软件系统提供的API接口采集或其它方式个人信息前, 未明确告知用户当前采集的个人信息种类以及采集的个人信息用途, 则判定等级为“风险”, 判定结束。
测评编号: 7.2.3
测评项目: 个人信息最少采集
项目要求: 6.1.3
预制条件: 被测移动智能终端以及人工智能应用可以正常启动并正常运行; 测评步骤: 步骤1: 检查移动智能终端人工智能应用是否具备用户信息保护政策条款; 步骤2: 如具备相关政策条款, 判断其中是否明示采集的用户个人信息类型; 步骤3: 如明示被采集的信息类型, 判断是否为实现产品或服务的业务功能直接关联; 步骤4: 如具备相关政策条款, 判断其中是否明示自动采集的用户个人信息的频率; 步骤5: 如明示自动采集的频率, 判断频率对实现产品或服务的业务功能是否合理、必要; 步骤6: 如具备相关政策条款, 判断其中是否明示间接获取用户个人信息数量; 步骤7: 如明示间接获取用户个人信息数量, 判断是否是实现产品或服务的业务功能所必需的最少数量; 步骤8: 运行移动智能终端人工智能应用, 观察其是否存在超出告知采集范围之外的行为。
预期结果: 在步骤1后, 如移动智能终端人工智能应用未提供用户信息保护政策条款, 则判定等级为“恶意”, 判定结束; 在步骤2后, 如未明示采集的用户个人信息类型, 则判定等级为“风险”, 判定结束, 否则转步骤3); 在步骤3后, 如明示采集的用户个人信息类型与实现产品或业务功能直接相关, 则转步骤4), 否则判定等级为“风险”, 判定结束; 在步骤4后, 如未明示自动采集的用户个人信息的频率, 则判定等级为“风险”, 判定结束, 否则转步骤5); 在步骤5后, 如明示自动采集的频率是实现产品或服务的业务功能所必需的最低频率, 则转步骤6), 否则判定等级为“风险”, 判定结束; 在步骤6后, 如未明示间接获取用户个人信息数量, 则判定等级为“风险”, 判定结束, 否则转步骤7); 在步骤7后, 如明示间接获取用户个人信息数量是实现产品或服务的业务功能所必需的最少数量, 则转步骤8); 否则判定等级为“风险”, 判定结束; 在步骤8后, 如人工智能应用程序存在超出告知范围的采集行为, 则判定等级为“恶意”, 判定结束; 否则判定为“未见异常”, 判定结束。

测评编号：7.2.4
测评项目：采集功能可配置或关闭
项目要求：6.1.4
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1，检查移动智能终端人工智能应用是否存在持续采集个人信息 步骤2，检查移动智能终端人工智能应用是否提供用户配置或关闭个人信息采集的机制或功能 步骤3，如移动智能终端人工智能应用提供用户配置或关闭个人信息采集的机制或功能，使用其机制或功能，判断与用户配置或关闭个人信息采集功能相符。
预期结果： 步骤1后，如移动智能终端人工智能应用不存在持续采集个人信息的行为，则判定等级为“未见异常”，判定结束； 步骤2后，如移动智能终端人工智能应用持续采集个人信息，且无用户配置或关闭个人信息采集的机制或功能，则判定等级为“恶意”，判定结束； 步骤3后，如移动智能终端人工智能应用提供用户配置或关闭个人信息采集的机制或功能，可使用户正常配置或关闭个人信息采集，则判定等级为“未见异常”，判定结束； 步骤3后，如移动智能终端人工智能应用提供用户配置或关闭个人信息采集的机制或功能，用户无法正常配置或关闭个人信息采集，则判定等级为“恶意”，判定结束。

测评编号：7.2.5
测评项目：无隐蔽手段或未告知的采集
项目要求：6.1.5
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：检查移动智能终端人工智能应用是否存在采集个人信息的行为； 步骤2：监控移动智能终端人工智能应用是否在未向用户明示且未经用户授权的情况下采集个人信息。
预期结果： 步骤1后，如移动智能终端人工智能应用不存在采集个人信息的行为，则判定等级为“未见异常”，判定结束； 步骤2后，如移动智能终端人工智能应用在未向用户明示且未经用户授权的情况下采集个人信息，则判定等级为“恶意”，判定结束； 步骤2后，如移动智能终端人工智能应用未采用隐蔽手段或间接方式采集个人信息，则判定等级为“未见异常”，判定结束。

测评编号：7.2.6
测评项目：敏感信息明示同意
项目要求：6.1.6
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：检查移动智能终端人工智能应用是否存在采集个人敏感信息和带生物特征的个人信息数据

步骤2: 如采集个人敏感信息和带生物特征的个人信息数据, 判断采集前是否取得个人信息主体的明示同意; 步骤3: 判断明示同意是否是在用户完全知情的基础上自愿给出的、具体的、清晰明确的愿望表示。
预期结果: 在步骤1后, 如移动智能终端人工智能应用不存在采集个人敏感信息和带生物特征的个人信息数据, 则判定等级为“未见异常”, 判定结束; 在步骤2后, 如采集前未取得个人信息主体的明示同意, 则判定等级为“恶意”, 判定结束; 在步骤3后, 如明示不是是在用户完全知情的基础上自愿给出的、具体的、清晰明确的愿望表示, 则判定等级为“风险”, 判定结束; 在步骤3后, 如明示是在用户完全知情的基础上自愿给出的、具体的、清晰明确的愿望表示, 则判定等级为“未见异常”, 判定结束。
测评编号: 7.2.7
测评项目: 告知有效期
项目要求: 6.1.7
预制条件: 被测移动智能终端以及人工智能应用可以正常启动并正常运行;
测评步骤: 步骤1: 判断移动智能终端人工智能应用是否提供用户信息保护政策条款; 步骤2: 判断政策条款里是否明确一个时间有效期, 包括一段时间或长期等。
预期结果: 在步骤1后, 如移动智能终端人工智能应用未提供用户信息保护政策条款, 则判定等级为“恶意”, 判定结束; 在步骤2后, 如未明确一个时间有效期, 则判定等级为“风险”, 判定结束, 否则判定等级为“未见异常”, 判定结束。

7.3 个人信息的训练

测评编号: 7.3.1
测评项目: 训练数据匿名化
项目要求: 6.2.1
预制条件: 被测移动智能终端以及人工智能应用可以正常启动并正常运行;
测评步骤: 步骤1: 审查厂商提交的说明文档, 检查人工智能应用所使用的训练数据是否涉及用户个人信息; 步骤2: 审查厂商提交的数据管理文档, 检查用作训练数据的用户个人信息数据, 使用前是否进行了匿名化处理; 查看存储于移动智能终端上作为训练数据的用户个人信息数据, 是否经过了匿名处理; 步骤3: 查看移动智能终端人工智能应用对未进行匿名化处理的用户个人信息训练数据, 使用前是否获得了用户的明示授权。
预期结果: 在步骤1后, 如移动智能终端人工智能应用所使用的训练数据未涉及用户个人信息, 则判定等级为“未见异常”, 判定结束; 在步骤2后, 如作为训练数据的用户个人信息数据进行了匿名化处理, 则判定等级为“未见异常”, 判定结束;

在步骤3后，如未进行匿名化处理的用户个人信息数据使用前获得了用户的明示授权，则判定等级为“未见异常”，否则，判定结果为“风险”，判定结束。

测评编号：7.3.2
测评项目：训练数据安全防护
项目要求：6.2.2
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：审查厂商提交的文档，检查人工智能应用所使用的训练数据是否涉及用户个人信息； 步骤2：审查厂商提交的文档，检查是否采用有效的安全机制，对训练数据进行安全防护； 步骤3：尝试对训练数据进行读取，检查安全防护机制是否有效；
预期结果： 在步骤1后，如移动智能终端人工智能应用所使用的训练数据未涉及用户个人信息，则判定等级为“未见异常”，判定结束； 在步骤2后，如未采取有效安全机制对训练数据进行安全防护，则判定等级为“风险”，判定结束； 在步骤3后，如安全防护机制无效，则判定等级为“风险”，否则判定为“未见异常”，判定结束。
测评编号：7.3.3
测评项目：AI模型安全防护
项目要求：6.2.3
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：审查厂商提交AI模型的安全防护设计文档，检查是否采用安全机制对AI模型进行防护； 步骤2：验证安全保护机制是否有效；
预期结果： 在步骤1后，如设计文档显示，未采用安全机制对AI模型进行防护，则判定等级为“风险”，判定结束； 在步骤2后，如AI模型防护机制无效，则判定等级为“风险”，否则判定为“未见异常”，判定结束。

7.4 个人信息分析

测评编号：7.4.1
测评项目：处理前告知
项目要求：6.3.1
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：查看移动智能终端人工智能应用，用户信息保护政策条款中是否对个人信息分析处理的目的、方法或手段进行告知； 步骤2：运行移动智能终端人工智能应用程序，观察其是否存在超出告知目的、方法或手段的分析用户个人信息的行为。

预期结果：

在步骤1后，如移动智能终端人工智能应用政策条款中未列出个人信息分析处理的目的、方法或手段，则判定等级为“恶意”，判定结束；

在步骤2后，如移动智能终端人工智能应用不存在超出告知目的、方法或手段的个人信息分析处理行为，则判定等级为“未见异常”，判定结束；

在步骤2后，如移动智能终端人工智能应用存在超出告知目的、方法或手段的个人信息分析处理行为，则判定等级为“恶意”，判定结束。

测评编号：7.4.2

测评项目：处理过程安全

项目要求：6.3.2

预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；

测评步骤：

步骤1：查看移动智能终端人工智能应用是否存在对用户个人信息分析处理过程；

步骤2：如存在对个人信息分析处理过程，则查看移动智能终端人工智能应用用户个人信息分析处理过程中，是否对个人信息数据进行了安全防护；

步骤3：查看安全防护方式和强度是否符合公共或商用标准。

预期结果：

在步骤1后，如移动智能终端人工智能应用不存在对用户个人信息分析处理过程，则判定等级为“未见异常”，判定结束；

在步骤2后，如移动智能终端人工智能应用未对用户个人信息分析处理过程进行安全防护，易被三方无关人员或组织获知，则判定等级为“风险”，判定结束；

在步骤3后，如安全防护处理方式和强度不符合公共或商用标准，则判定等级为“风险”，否则判定等级为“未见异常”，判定结束。

测评编号：7.4.3

测评项目：处理系统安全

项目要求：6.3.3

预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；

测评步骤：

步骤1：查看移动智能终端人工智能应用是否存在对用户个人信息分析处理过程；

步骤2：查看移动智能终端人工智能应用是否在分析处理过程完毕时进行数据完整性和正确性检查。

预期结果：

在步骤1后，如移动智能终端人工智能应用不存在对个人信息加工处理过程，则判定等级为“未见异常”，判定结束；

在步骤2后，如移动智能终端人工智能应用在个人信息分析处理过程完毕时进行数据完整性和正确性检查，则判定等级为“未见异常”，判定结束；

在步骤2后，如移动智能终端人工智能应用在个人信息分析处理过程完毕时未进行数据完整性和正确性检查，则判定等级为“风险”，判定结束。

测评编号：7.4.4

测评项目：处理过程可控

项目要求：6.3.4
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：查看移动智能终端人工智能应用是否存在对用户个人信息分析处理过程； 步骤2：查看使用者是否可配置或关闭分析过程。
预期结果： 在步骤1后，如移动智能终端人工智能应用不存在对个人信息加工处理过程，则判定等级为“未见异常”，判定结束； 在步骤2后，如果使用者可配置或关闭分析过程，则判定等级为“未见异常”，否则，判定结果为“恶意”，判定结束。

测评编号：7.4.5
测评项目：无隐蔽处理
项目要求：6.3.5
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：判断移动智能终端人工智能应用是否提供用户个人信息保护政策条款； 步骤2：判断政策条款里是否承诺在分析处理过程中不采取未告知并获得用户同意的技术手段获取、挖掘和分析归纳用户的个人信息数据。
预期结果： 在步骤1后，如移动智能终端人工智能应用未提供用户信息保护政策条款，则判定等级为“恶意”，判定结束； 在步骤2后，如存在隐蔽手段，获取、挖掘和分析归纳用户的个人信息，则判定等级为“恶意”，判定结束；如未承诺在个人信息分析处理过程中不采取隐蔽手段获取、挖掘和分析归纳用户的一般个人信息数据，则判定等级为“风险”，判定结束，否则判定等级为“未见异常”，判定结束。

测评编号：7.4.6
测评项目：敏感信息明示授权
项目要求：6.3.6
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：判断移动智能终端人工智能应用是否提供用户个人信息保护政策条款； 步骤2：判断政策条款里是否承诺不会对数据进行组合分析，产生个人敏感信息； 步骤3：如果会通过通过对数据进行组合分析，产生个人敏感信息，判断组合分析前，是否向用户明示了组合分析的目的、数据来源、使用范围等，并获得用户授权。
预期结果： 在步骤1后，如移动智能终端人工智能应用未提供用户信息保护政策条款，则判定等级为“恶意”，判定结束； 在步骤2后，如政策条款里承诺了不会对数据进行组合分析产生个人敏感信息，则判定等级为“未见异常”，判定结束； 在步骤3后，如在组合分析前，向用户明示了组合分析的目的、数据来源、使用范围等，并获得用户授权，则判定等级为“未见异常”，否则，判定等级为“恶意”，判定结束。

测评编号：7.4.7
测评项目：申诉方法提供
项目要求：6.3.7
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：判断移动智能终端人工智能应用是否会依据自动决策做出显著影响个人信息主体权益的决定； 步骤2：判断是否向个人信息主体提供了针对自动决策的申诉方法。
预期结果： 在步骤1后，如移动智能终端人工智能应用不会依据自动决策做出显著影响个人信息主体权益的决定，则判定等级为“未见异常”，判定结束； 在步骤2后，如向个人信息主体提供了针对自动决策的申诉方法，则判定等级为“未见异常”，否则判定等级为“风险”，判定结束。

7.5 个人信息的存储

测评编号：7.5.1
测评项目：存储识别
项目要求：6.4.1
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：结合厂商提供的说明文档，运行移动智能终端人工智能应用，检测其是否存在存储用户个人数据的行为； 步骤2：判断个人数据存储的形式能够识别数据主体的程度是否超过数据处理目的的需要。
预期结果： 在步骤1后，如移动智能终端人工智能应用不存在存储用户个人数据的行为，则判定等级为“未见异常”，判定结束； 步骤2，如个人数据存储的形式能够识别数据主体的程度超过了数据处理目的的需要，则判定等级为“风险”，否则判定等级为“未见异常”，判定结束。

测评编号：7.5.2
测评项目：最小授权
项目要求：6.4.2
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：查看厂商提供的设计文档，检查是否采用角色分离的方式对移动智能终端上人工智能应用所涉个人信息数据进行访问控制； 步骤2：使用合法和非法账户/应用访问个人信息数据，检查访问控制机制的有效性； 步骤3：判断基于角色分离的访问控制机制，是否遵循最小授权原则。
预期结果：

在步骤1后，如移动智能终端人工智能应用未采用角色分离的方式对移动智能终端上人工智能应用所涉个人信息数据进行访问控制，则判定等级为“恶意”，判定结束；

在步骤2后，如访问控制机制存在缺陷，可能导致非授权的访问，则判定等级为“风险”，判定结束

步骤3，如访问控制机制未遵循最小授权原则，则判定等级为“风险”，否则判定等级为“未见异常”，判定结束。

测评编号：7.5.3

测评项目：访问控制

项目要求：6.4.3

预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；

测评步骤：

步骤1：访谈厂商，并结合厂商提供的文档，检查移动智能终端人工智能应用是否存在存储用户位置轨迹类、行为习惯、身份信息、设备信息和业务信息类数据的行为；

步骤2：如存在存储用户位置轨迹类、行为习惯、身份信息、设备信息和业务信息类数据的行为，则判断其是否为保存数据的文件设置适当的权限，以防止未授权的访问。

预期结果：

在步骤1后，如移动智能终端人工智能应用不存在存储用户位置轨迹类、行为习惯、身份信息、设备信息和业务信息类数据的行为，则判定等级为“未见异常”，判定结束；

在步骤2后，如未为文件设置适当的权限，则判定等级为“风险”，否则，判定等级为“未见异常”，判定结束。

测评编号：7.5.4

测评项目：敏感数据安全存储

项目要求：6.4.4

预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；

测评步骤：

步骤1：访谈厂商，并结合厂商提供的文档，检查移动智能终端人工智能应用是否存在存储用户生物特征类、账户凭证类数据的行为；

步骤2：如果存储用户生物特征类、账户凭证类数据，则判断其是否是对相关信息进行单向变换（通常使用单向散列函数）后再进行保存；

步骤3：结合厂商提供的文档，判断单项变换是否增加了盐值。

预期结果：

在步骤1后，如移动智能终端人工智能应用不存在存储用户生物特征类、账户凭证类数据的行为，则判定等级为“未见异常”，判定结束；

在步骤2后，如未对用户生物特征类、账户凭证类数据进行单向变换而是直接保存，则判定等级为“风险”，判定结束；

在步骤3后，如进行了单项变换但未添加盐值，则判定等级为“风险”，否则，判定等级为“未见异常”，判定结束。

测评编号：7.5.5

测评项目：敏感数据安全存储

项目要求：6.4.5

预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：访谈厂商，并结合厂商提供的文档，检查移动智能终端人工智能应用是否存在存储用户生物特征类、账户凭证类数据的行为； 步骤2：如存在存储用户生物特征类、账户凭证类数据的行为，则判断其是否将其存储在受保护的系統区域内，并且为其设置适当的权限，以防止未授权的访问。
预期结果： 在步骤1后，如移动智能终端人工智能应用不存在存储用户生物特征类、账户凭证类数据的行为，则判定等级为“未见异常”，判定结束； 在步骤2后，如未存储在受保护的系統区域内，则判定等级为“风险”，判定结束；如存储在受保护的系統区域内但并未为其设置适当的权限，则判定等级为“风险”，否则，判定等级为“未见异常”，判定结束。

测评编号：7.5.6
测评项目：最短保存期限
项目要求：6.4.6
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：检查移动智能终端人工智能应用是否具备用户信息保护政策条款； 步骤2：如具备相关政策条款，检查其中是否向用户承诺用户个人信息保存期限为实现目的所必需的最短时间。超出上述个人信息保存期限后，会对个人信息进行删除或匿名化处理；
预期结果： 在步骤1后，如移动智能终端未提供用户信息保护政策条款，则判定等级为“恶意”，判定结束； 在步骤2后，如条款中承诺了用户个人信息保存期限为实现目的所必需的最短时间，且超出上述个人信息保存期限后，会对个人信息进行删除或匿名化处理，则判定等级为“未见异常”，判定结束，否则判定等级为“风险”，判定结束。

测评编号：7.5.7
测评项目：存储隔离
项目要求：6.4.7
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：访谈并查看厂商提供的文档，检查个人信息存储前，是否立即进行了去标识化处理； 步骤2：访谈并查看厂商提供的文档，检查去标识化后的数据与可用于恢复识别个人的信息是否分开存储； 步骤3：检查去标识化后的数据存储位置是否与可用于恢复识别个人的信息分隔；步骤4：查看相关政策条款，检查其中是否向用户承诺去标识化后的数据在不借助外部数据的前提下，在应用内后续处理中不能重新识别个人；
预期结果： 在步骤1后，如个人信息存储前，没有立即进行了去标识化处理，则判定等级为“风险”，判定结束；

在步骤2后，如去标识化后的数据与可用于恢复识别个人的信息没有分开存储，则判定等级为“风险”，判定结束；
在步骤3后，如果去标识化后数据的实际存储位置未与可用于恢复识别个人的信息分隔，则判定等级为“风险”，判定结束；
在步骤4后，如果相关政策条款中未向用户承诺去标识化后的数据在后续的个人信息处理中不会与其他信息结合重新识别个人，则判定等级为“风险”，否则判定等级为“未见异常”，判定结束。

7.6 个人信息的转移

测评编号：7.6.1
测评项目：转移告知
项目要求：6.5.1
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：运行移动智能终端人工智能应用，查看其是否告知用户个人信息转移的目的、转移信息的获得者、转移数据的使用范围，或向用户承诺，不会将用户个人信息转移至第三方；
预期结果： 在步骤1后，如用户个人信息转移前，向用户告知了个人信息转移的目的、转移信息的获得者、转移数据的使用范围，则判定等级为“未见异常”；如向用户承诺不会将用户个人信息转移至第三方，则判定等级为“未见异常”；否则判定等级为“恶意”，判定结束。

测评编号：7.6.2
测评项目：超范围转移
项目要求：6.5.2
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：查看移动智能终端人工智能应用用户信息保护政策条款中的转移的目的、转移信息的获得者、转移数据的使用范围； 步骤2：运行移动智能终端人工智能应用，观察其是否存在超出告知转移目的、转移信息获得者、转移数据使用范围转移用户个人信息的行为。
预期结果： 在步骤1后，如移动智能终端人工智能应用政策条款中未列出转移的目的、转移信息的获得者、转移数据的使用范围，且未承诺不会将用户个人信息转移至第三方，则判定等级为“恶意”，判定结束； 在步骤2后，如移动智能终端人工智能应用不存在超出告知目的、获得者或使用范围的转移行为，则判定等级为“未见异常”，判定结束； 在步骤2后，如移动智能终端人工智能应用存在超出告知目的、获得者或使用范围的转移行为，则判定等级为“恶意”，判定结束。

测评编号：7.6.3
测评项目：最少转移
项目要求：6.5.3
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；

测评步骤： 步骤1：查看移动智能终端人工智能应用用户信息保护政策条款中的转移的目的、获得者、转移数据的使用范围，判断是否符合最少够用原则。
预期结果： 在步骤1后，如告知的目的、获得者或使用范围的满足最少够用原则，则判定等级为“未见异常”，否则判定等级为“风险”，判定结束。
测评编号：7.6.4
测评项目：敏感信息转移前告知
项目要求：6.5.4
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：判断移动智能终端人工智能应用是否存在生物特征类和账户凭证类等涉及个人敏感信息或生物特征个人信息的转移行为； 步骤2：判断转移前是否获得用户的授权同意。
预期结果： 在步骤1后，如不存在生物特征类和账户凭证类等涉及个人敏感信息或生物特征个人信息的转移行为，则判定等级为“未见异常”，判定结束； 在步骤2后，转移前获得了用户的授权同意，则判定等级为“未见异常”，否则判定等级为“恶意”，判定结束。
测评编号：7.6.5
测评项目：转移的完整性和保密性
项目要求：6.5.5
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1：判断转移的用户个人信息是否通过公共网络； 步骤2：如是通过公共网络转移用户个人信息，则判断是否对信息进行加密； 步骤3：判断加密处理方式和强度是否符合公共或商用标准。
预期结果： 在步骤1后，如不是通过公共网络转移用户个人信息，则判定等级为“未见异常”，判定结束； 在步骤2后，如对信息进行加密，则判定等级为“未见异常”，判定结束； 在步骤2后，如未对信息进行加密，则判定等级为“风险”，判定结束； 在步骤3后，如对信息进行加密但加密处理方式和强度不符合公共或商用标准，则判定等级为“风险”，否则判定等级为“未见异常”，判定结束。
测评编号：7.6.6
测评项目：过程可控
项目要求：6.5.6
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤：

步骤1:如移动智能终端人工智能应用存在转移用户个人信息的行为,则查看移动智能终端人工智能应用是否提供对当前转移用户个人信息进行配置或关闭操作的功能;

步骤2:如提供了配置或关闭转移用户个人信息的功能,则在使用此功能的前提下,使用配置或关闭操作功能,结果与预期目的一致。

预期结果:

步骤1后,如移动智能终端人工智能应用不存在转移用个人信息的行为,则判定等级为“未见异常”,判定结束;

步骤1后,如移动智能终端人工智能应用存在转移用户个人信息的行为,移动智能终端人工智能应用不提供对转移用户个人信息进行配置或关闭操作的功能,则判定等级为“恶意”,判断结束;

步骤2后,如移动智能终端人工智能应用存在转移用户个人信息的行为,移动智能终端人工智能应用提供对转移用户个人信息进行配置或关闭操作的功能,配置或关闭操作等功能与预期目的一致,则判定等级为“未见异常”,判定结束;

步骤2后,如移动智能终端人工智能应用存在转移用户个人信息的行为,移动智能终端人工智能应用提供对转移用户个人信息进行配置或关闭操作的功能,配置或关闭操作等功能与预期目的不一致,则判定等级为“风险”,判定结束。

7.7 个人信息的共享与转让

测评编号: 7.7.1

测评项目: 重视风险

项目要求: 6.6.1

预制条件: 被测移动智能终端以及人工智能应用可以正常启动并正常运行;

测评步骤:

步骤1:访谈厂商、查看厂商提供的文档,判断移动智能终端人工智能应用是否存在向第三方共享、转让用户个人信息的行为;

步骤2:访谈厂商、查看厂商提供的文档,判断个人信息控制者是否制定相关风险管理和应急响应预案,重视共享、转让环节可能存在的风险。

预期结果:

步骤1后,如移动智能终端人工智能应用不存在共享、转让用个人信息的行为,则判定等级为“未见异常”,判定结束;

步骤2后,如移动智能终端人工智能应用存在共享、转让用户个人信息的行为,但个人信息控制者没有制定相关风险管理和应急响应预案,则判定等级为“风险”,判定结束;

步骤2后,如移动智能终端人工智能应用存在共享、转让用户个人信息的行为,个人信息控制者制定了相关风险管理和应急响应预案,则判定等级为“未见异常”,判定结束。

测评编号: 7.7.2

测评项目: 告知与授权同意

项目要求: 6.6.2

预制条件: 被测移动智能终端以及人工智能应用可以正常启动并正常运行;

测评步骤:

步骤1:运行移动智能终端人工智能应用,查看其是否告知用户共享、转让个人信息的目的、数据接收方的类型,或向用户承诺不会将用户个人信息共享、转让至第三方;

步骤2: 查看是否事先征得个人信息主体的授权同意。
预期结果: 步骤1后, 如移动智能终端人工智能应用不存在共享、转让用个人信息的行为, 则判定等级为“未见异常”, 判定结束; 步骤1后, 如移动智能终端人工智能应用存在共享、转让用户个人信息的行为, 但未向用户告知共享、转让个人信息的目的、数据接收方的类型以及可能产生的后果, 则判定等级为“风险”, 判定结束 步骤1后, 如移动智能终端人工智能应用存在共享、转让用户个人敏感信息的行为, 但未向用户告知告知涉及的个人敏感信息类型、数据接收方的身份和数据安全能力, 则判定等级为“恶意”; 步骤1后, 如移动智能终端人工智能应用存在共享、转让用户个人信息的行为, 向用户告知共享、转让个人信息的相关信息, 则转步骤2; 步骤2后, 如事先征得了用户个人信息主体的授权同意, 则判定等级为“未见异常”, 否则判定等级为“恶意”, 判定结束。

测评编号: 7.7.3
测评项目: 撤销同意
项目要求: 6.6.3
预制条件: 被测移动智能终端以及人工智能应用可以正常启动并正常运行;
测评步骤: 步骤1: 运行移动智能终端人工智能应用, 查看其是否告知用户共享、转让个人信息的目的、数据接收方的类型, 或向用户承诺不会将用户个人信息共享、转让至第三方; 步骤2: 查看是否提供撤回共享、转让授权同意的方法。
预期结果: 步骤1后, 如移动智能终端人工智能应用不存在共享、转让用个人信息的行为, 则判定等级为“未见异常”, 判定结束; 步骤1后, 如移动智能终端人工智能应用存在共享、转让用户个人信息的行为, 但未向用户告知共享、转让个人信息的目的、数据接收方的类型, 则判定等级为“恶意”, 判定结束; 步骤1后, 如移动智能终端人工智能应用存在共享、转让用户个人信息的行为, 向用户告知共享、转让个人信息的目的、数据接收方的类型, 则转步骤2; 步骤2后, 如提供撤回共享、转让授权同意的方法, 则判定等级为“未见异常”, 否则判定等级为“恶意”, 判定结束。

测评编号: 7.7.4
测评项目: 不超范围共享转让
项目要求: 6.6.4
预制条件: 被测移动智能终端以及人工智能应用可以正常启动并正常运行;
测评步骤: 步骤1: 查看移动智能终端人工智能应用用户信息保护政策条款中的共享、转让的目的、对象、范围; 步骤2: 运行移动智能终端人工智能应用, 观察其是否存在超出告知共享、转让目的、对象、范围共享、转让用户个人信息的行为。

预期结果：

在步骤1后，如移动智能终端人工智能应用政策条款中未列出共享、转让的目的、范围，且未承诺不会将用户个人信息共享、转让至第三方，则判定等级为“恶意”，判定结束；

在步骤2后，如移动智能终端人工智能应用不存在超出告知目的、范围的共享、转让行为，则判定等级为“未见异常”，判定结束；

在步骤2后，如移动智能终端人工智能应用存在超出告知目的、范围的共享、转让行为，则判定等级为“恶意”，判定结束。

7.8 个人信息的披露

测评编号：7.8.1

测评项目：告知与授权同意

项目要求：6.7.1

预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；

测评步骤：

步骤1: 访谈厂商、查看厂商提供的文档，判断移动智能终端人工智能应用是否存在公开披露用户个人信息的行为；

步骤2: 运行移动智能终端人工智能应用，查看其是否告知用户公开披露个人信息的目的、类型；

步骤3: 查看是否事先征得个人信息主体的授权同意。

预期结果：

步骤1后，如移动智能终端人工智能应用不存在公开披露用户个人信息的行为，则判定等级为“未见异常”，判定结束；

步骤2后，如移动智能终端人工智能应用存在公开披露用户个人信息的行为，但未向用户告知公开披露个人信息的目的、类型，则判定等级为“恶意”，判定结束；

步骤2后，如移动智能终端人工智能应用存在公开披露用户个人信息的行为，向用户告知了公开披露个人信息的目的、类型，则转步骤3；

步骤3后，如事先征得了用户个人信息主体的授权同意，则判定等级为“未见异常”，否则判定等级为“恶意”，判定结束。

测评编号：7.8.2

测评项目：敏感信息披露告知

项目要求：6.7.2

预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；

测评步骤：

步骤1: 访谈厂商、查看厂商提供的文档，判断移动智能终端人工智能应用是否存在公开披露用户个人敏感信息的行为；

步骤2: 运行移动智能终端人工智能应用，查看其是否告知用户公开披露个人敏感信息的具体内容。

预期结果：

步骤1后，如移动智能终端人工智能应用不存在公开披露用户个人敏感信息的行为，则判定等级为“未见异常”，判定结束；

步骤2后，如移动智能终端人工智能应用存在公开披露用户个人敏感信息的行为，向用户告知了公开披露个人敏感信息的具体内容，则判定等级为“未见异常”，否则判定等级为“恶意”，判定结束；

测评编号：7.8.3
测评项目：违规披露
项目要求：6.7.3
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1: 访谈厂商、查看厂商提供的文档，判断移动智能终端人工智能应用是否存在未经用户同意，公开披露用户个人信息的行为； 步骤2: 访谈厂商、查看厂商提供的文档，判断移动智能终端人工智能应用是否存在披露生物特征类、位置轨迹类、账户凭证类个人敏感信息的行为； 步骤3: 判断移动智能终端人工智能应用披露用户个人敏感信息，是否获得用户明示同意。
预期结果： 步骤1后，如移动智能终端人工智能应用不存在公开披露用户个人信息的行为，则判定等级为“未见异常”，判定结束； 步骤1后，如存在公开披露用户个人信息的行为，判断是否获得用户同意，如获得同意，则转步骤2，如未获得同意，则判断是否涉及用户个人敏感信息，如涉及则转步骤2，如不涉及，则判定等级为“风险”，判定结束； 步骤2、3后，如存在公开披露用户生物特征类、位置轨迹类、账户凭证类个人敏感信息的行为，则判断是否获得用户明示同意，如获得明示同意，则判定等级为“未见异常”，如未获得明示同意，则判定等级为“恶意”，判定结束。

7.9 个人信息的删除

测评编号：7.9
测评项目：个人信息的删除
项目要求：6.8
预制条件：被测移动智能终端以及人工智能应用可以正常启动并正常运行；
测评步骤： 步骤1，检查移动智能终端人工智能应用是否对所使用的个人信息的进行缓存； 步骤2，如移动智能终端人工智能应用对所使用的个人信息进行缓存，查看移动智能终端人工智能应用是否提供自动删除缓存功能； 步骤3，如移动智能终端人工智能应用提供自动删除缓存功能，转步骤5； 步骤4，如移动智能终端人工智能应用不提供自动删除缓存功能，转步骤5； 步骤5，使用移动智能终端人工智能应用提供的删除功能对数据进行彻底删除； 步骤6，使用工具对步骤5中彻底删除的数据进行恢复。
预期结果： 步骤6后，如移动智能终端人工智能应用使用自动删除缓存功能后，缓存数据被正常删除，则判定等级为“未见异常”，判定结束； 步骤6后，如移动智能终端人工智能应用使用自动删除缓存功能后，缓存数据未被删除，则判定等级为“风险”，判定结束； 步骤6，后，如移动智能终端人工智能应用缓存数据可被手动删除，则判定等级为“未见异常”，判定结束；

步骤6后，如移动智能终端人工智能应用缓存数据无法被手动删除，则判定等级为“恶意”，判定结束。

参 考 文 献

- YD/T 3082-2016 移动智能终端上的个人信息保护技术要求
YD/T 2407-2021 移动智能终端安全能力技术要求
-